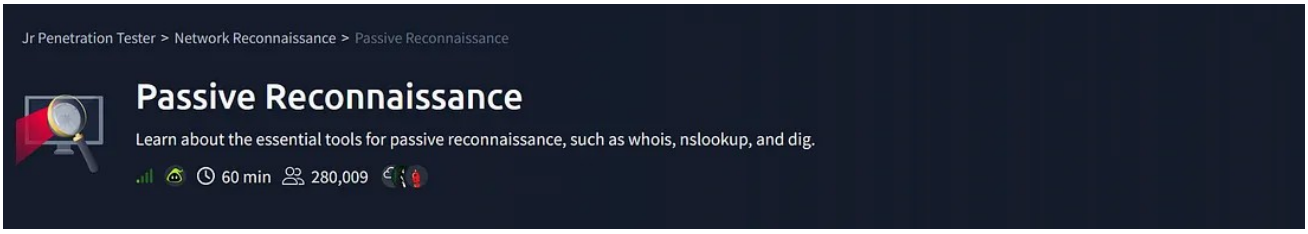
Open in app ↗

Medium

Access to everything. Now 30% off. Upgrade now



Passive Reconnaissance +

Passive Reconnaissance “TRYHACKME WALKTROUGH”

13 min read · Just now

Nuh hozar

Listen Share More

Task 1- Introduction

Welcome to the **Passive Reconnaissance** room. This is the starting point of TryHackMe’s Network Security Module.

In this room, **passive reconnaissance** refers to gathering intelligence from public sources without contacting the target. This stands in contrast to **active reconnaissance**, where you interact with the target directly and risk detection.

Passive recon remains one of the most powerful and lowest-risk phases in penetration testing, bug bounties, and threat hunting. Even with stronger privacy laws (GDPR, CCPA), large amounts of useful data remain publicly exposed through DNS, WHOIS, certificate logs, search engines, and device census platforms.

Objectives

By the end of this room, you will be able to:

- Use `whois` to query domain registration details.
- Use `dig` (and `nslookup` for compatibility) to query DNS records.
- Understand why querying public WHOIS and DNS servers is considered passive.
- Discover subdomains using DNSDumpster and Certificate Transparency logs.
- Gather intelligence on exposed services using Shodan.io.

Prerequisites

This room assumes basic networking concepts and comfort with the Linux terminal. If you need a refresher, complete the following first:

- Networking
- Linux Fundamentals

Important Notice: If you are not a subscriber, the in-browser **AttackBox** has no direct Internet access. For any questions requiring web lookups (DNSDumpster, Shodan, crt.sh, etc.), connect via **OpenVPN** to the TryHackMe network. This gives your local machine (or AttackBox with VPN) full Internet connectivity.

No deployment is needed for this room. All exercises use public Internet data, mostly TryHackMe-related domains for examples.

Task -2 Passive Versus Active Recon

Before computer networks existed, Sun Tzu wrote in *The Art of War*: “If you know the enemy and know yourself, your victory will not stand in doubt.”

In cybersecurity, this principle maps to two roles. As an attacker (or ethical hacker), you gather intelligence about the target to find weaknesses. As a defender, you must understand what an adversary can discover about your systems from public sources and minimise that exposure.

Reconnaissance (recon) is the preliminary survey to collect information about a target. It remains the first phase in modern attack frameworks like the **Unified Kill Chain** (where recon helps gain initial understanding before any foothold) and variations of the classic Cyber Kill Chain. Reconnaissance divides into two main types.

Passive Reconnaissance

Passive reconnaissance relies exclusively on publicly available information. No packets are sent to the target and no direct interaction occurs. It is analogous to observing the target territory from a safe distance using binoculars, without ever stepping onto their land.



Common passive activities include:

- Querying public DNS records from open resolvers (A, MX, TXT, etc.).
- Searching certificate transparency logs (e.g., crt.sh) for subdomains and

issued certificates.

- Reviewing job postings on LinkedIn or company career pages for tech stack hints.
- Reading public news, press releases, or leaked documents on paste sites.
- Checking exposed devices via search engines like Shodan or Censys.
- Scanning public GitHub repositories for hardcoded credentials or configuration files.

Active Reconnaissance

Active reconnaissance requires direct engagement with the target. Your probes can be logged, detected, or blocked. It is analogous to walking up to the doors and windows to test locks, cameras, and alarms.



Common active activities include:

- Sending packets to discover live hosts (e.g., ICMP pings, ARP requests).
- Port scanning or service enumeration (Nmap, masscan).
- Interacting with web applications or APIs (fuzzing endpoints, directory brute-forcing).
- Social engineering attempts (phishing, vishing, pretexting phone calls).
- Physical approaches (tailgating, posing as a vendor).

Because active reconnaissance is detectable (IDS/IPS, WAFs, logging), it carries a higher risk of alerting the target. Without explicit authorisation (e.g., bug bounty scope or pentest contract), it can lead to legal issues. Passive recon is far stealthier and is often the practical first step.

Note that any direct interaction with a person affiliated with the target also counts as active reconnaissance, even when no packets are involved. For example, attending a social event and asking an employee about their company’s technology stack is active reconnaissance because you are directly engaging with the target organisation.

Defender tip: Organisations now monitor their own passive footprint using alerts from Shodan/Censys, CT log watchers, and automated OSINT tools to reduce what attackers can find without ever touching the network.

Answer the questions below

Q 1-You visit the Facebook page of the target company, hoping to get some of their employee names. What kind of reconnaissance activity is this? (A for active, P for passive)

Answer : P

Q 2- You ping the IP address of the company webserver to check if ICMP traffic is blocked. What kind of reconnaissance activity is this? (A for active, P for passive)

Answer :A

Q 3- You happen to meet the IT administrator of the target company at a party. You try to use social engineering to get more information about their systems and network infrastructure. What kind of reconnaissance activity is this? (A for active, P for passive)

Answer : A

Task 3- Whois

WHOIS is a query/response protocol defined in RFC 3912. WHOIS servers listen on **TCP port 43** and provide registration details for domain names. The **domain registrar** maintains these records for the domains they lease.

From a WHOIS response, the following details may be available (when not redacted):

- **Registrar**: The company (e.g., Namecheap, GoDaddy) that registered the domain.
- **Registrant contact information**: Name, organisation, address, phone, and email. However, **privacy services** (standard since GDPR 2018) usually replace this with “Withheld for Privacy” or similar.
- **Dates**: Creation (registration), Updated (last change), and Expiration (renewal deadline).
- **Name servers**: The DNS servers authoritative for the domain.
- **Status codes**: For example, `clientTransferProhibited` indicates the domain is locked against unauthorised transfers.
- **Abuse contacts**: The registrar’s email and phone for reporting issues.

Full personal details are now rare due to privacy laws (GDPR, CCPA) and widespread use of privacy proxies. In practice, attackers focus on dates (for estimating age or timing social engineering around renewal periods), the registrar (for phishing patterns), name servers (potential weak points), and

historical changes. Services like whoxy.com provide historical WHOIS snapshots. Historical WHOIS data can reveal previous owners, registrar changes, or name server migrations that may indicate past compromises or infrastructure shifts.

WHOIS Is Being Replaced By RDAP

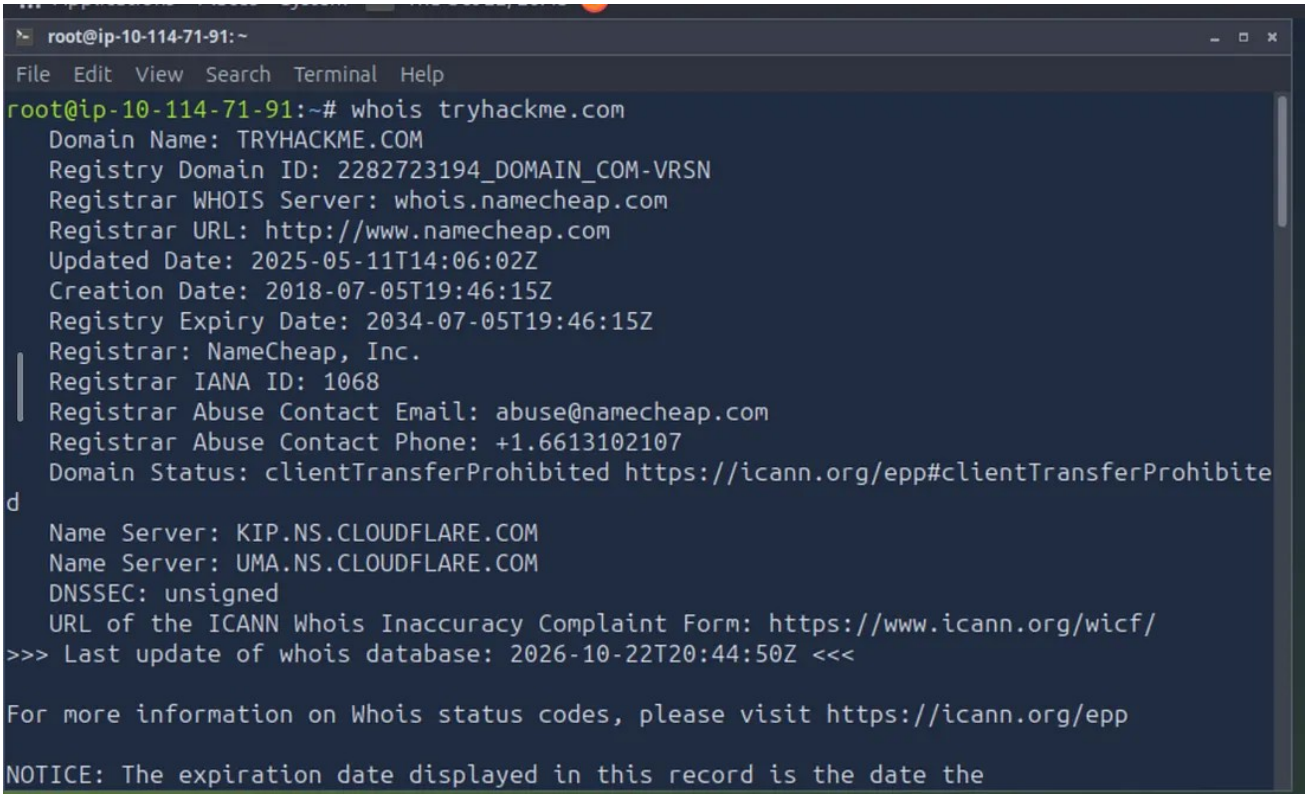
As of 28 January 2025, ICANN officially sunsetted the traditional WHOIS protocol for generic top-level domains (gTLDs) in favour of the **Registration Data Access Protocol (RDAP)**. RDAP is the modern successor: it uses HTTPS (secure), returns structured JSON (machine-readable and consistent), supports internationalisation, provides better privacy controls (differentiated access), and aligns with current data protection rules. While legacy `whois`

clients still work (often via failover or older servers), RDAP is now the authoritative standard. Many tools and browsers redirect to RDAP automatically, and command-line access is straightforward with `curl` or dedicated clients like OpenRDAP.

To query WHOIS, use the `whois`

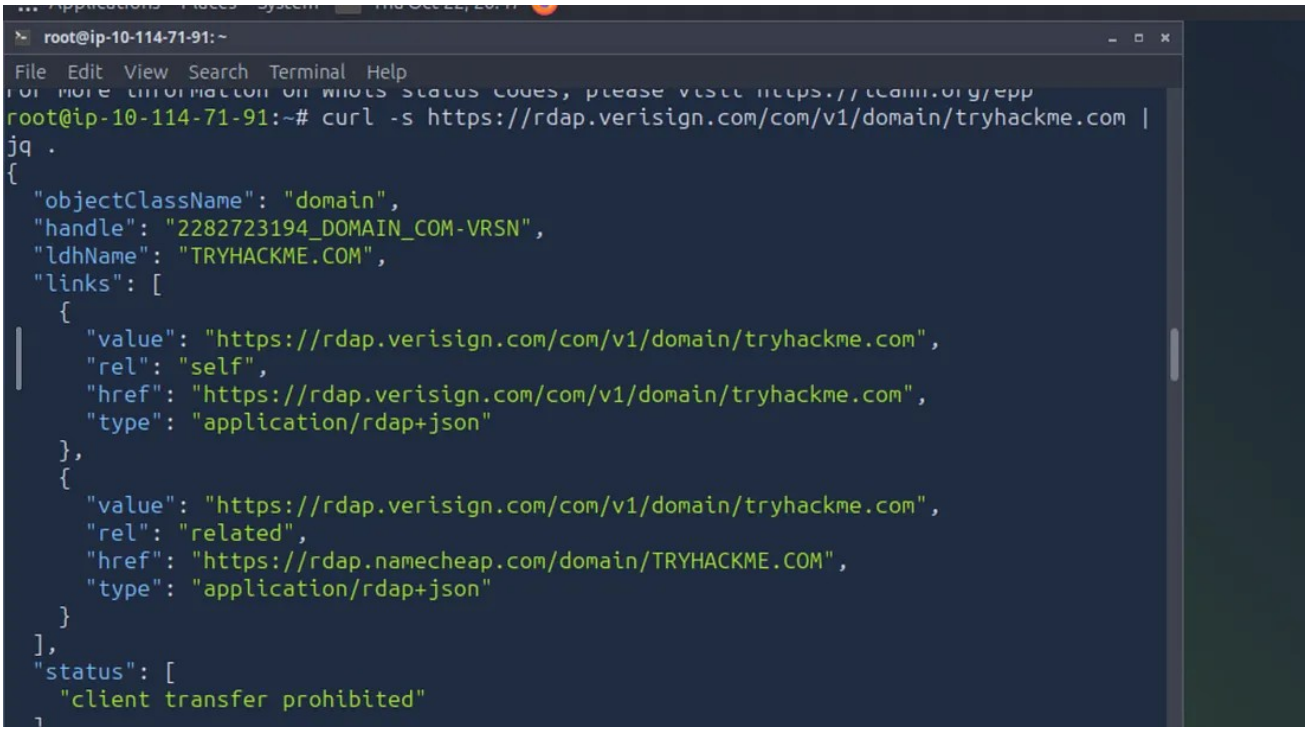
command-line client (faster than most web tools) or online viewers for legacy queries.

Syntax: `whois DOMAIN_NAME`



RDAP example

Use `curl` to query a public RDAP endpoint (e.g., Verisign for `.com` domains). The `jq` utility formats the JSON output for readability; it is pre-installed on the AttackBox. If you are using your own system, install it via your package manager (e.g., `sudo apt install jq`).



RDAP output is structured (easy to parse and script) and more secure. Expect to see this format increasingly in modern tooling.

What to look for:

- Redirection chain (Verisign to registrar server).
- Dates: useful for estimating company age or identifying renewal phishing windows.
- Name servers: potential new targets (if in scope).
- Status: locked domains (e.g., `clientTransferProhibited`) are harder to hijack.

Online alternatives (if the `whois` command behaves unexpectedly):

- https://whois.icann.org/ (legacy WHOIS)
- https://lookup.icann.org/ (modern RDAP-focused lookup)
- https://www.whoxy.com/ (historical WHOIS snapshots, free limited use)

On the AttackBox, open a terminal and run `whois tryhackme.com` (or try the RDAP curl example) to answer the following questions.

Q 4- When was TryHackMe.com registered?

Answer : 20180705

Q 5- What is the registrar of TryHackMe.com?

Answer : namecheap.com

Q 6- Which company is TryHackMe.com using for name servers?

Answer : cloudflare.com

Task 4- nslookup and dig

In the previous task, WHOIS gave us the authoritative name servers for the domain. This task moves to querying DNS records, which is still fully **passive**

because the queries go to public or open resolvers, not to the target’s servers directly.

These tools translate domain names to IP addresses, find mail servers, reveal TXT records (SPF, DMARC, verification strings), and more.

Why prefer dig over nslookup?

This task introduces two DNS query tools: `nslookup`

and `dig`. Both query DNS, but `dig` (historically a backronym for "Domain Information Groper") is the modern, preferred option. It provides cleaner output, displays TTL values by default (showing how long records are cached), and is more reliable for complex queries and scripting. `nslookup` is covered here for compatibility, since you will encounter it in older documentation and on Windows systems, but `dig` should be your default tool.

nslookup

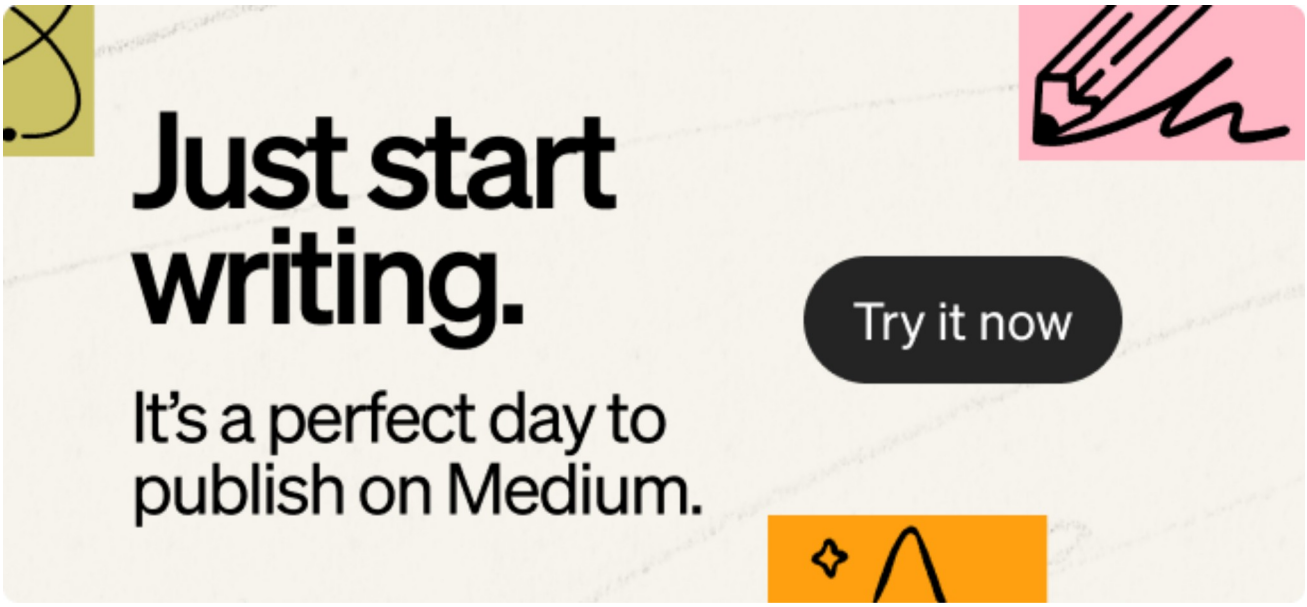
nslookup (Name Server Lookup) is the older of the two tools.

Syntax:

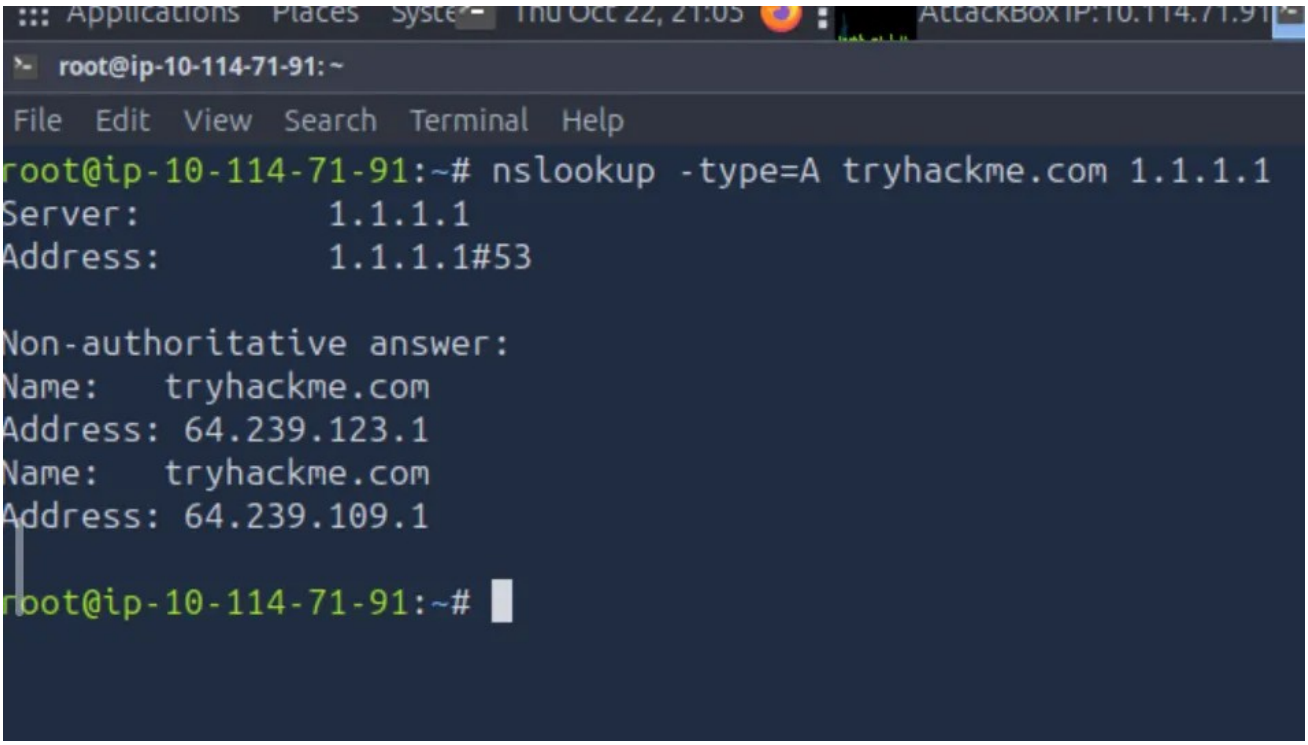
- `nslookup DOMAIN_NAME` performs a simple lookup using your default resolver.
- `nslookup -type=TYPE DOMAIN_NAME [SERVER]` specifies a record type and an optional DNS server.

Common DNS record types:

Query type Result A IPv4 address(es) for the domain AAAA IPv6 address(es) for the domain CNAME Canonical Name: an alias that points one domain name to another MX Mail Servers: the servers responsible for handling email for the domain SOA Start of Authority: the primary name server, admin email, and zone serial number TXT Text Records: arbitrary text, commonly used for SPF, DKIM, DMARC, and domain verification



Example (IPv4 addresses via Cloudflare’s resolver):



These IPs are often anycast (Cloudflare in this case). For penetration testing, each IP may host different services, so check whether they fall within scope.

MX example (mail servers):

```
root@ip-10-114-71-91:~# nslookup -type=MX tryhackme.com
Server:         127.0.0.1
Address:        127.0.0.1#53

Non-authoritative answer:
*** Can't find tryhackme.com: No answer

Authoritative answers can be found from:
tryhackme.com
        origin = ns-1536.awsdns-00.co.uk
        mail addr = awsdns-hostmaster.amazon.com
        serial = 1
        refresh = 7200
        retry = 900
        expire = 1209600
        minimum = 86400

root@ip-10-114-71-91:~#
```

mail servers

The number before each server indicates priority: lower values mean higher priority. In this case, Google Workspace handles email, which is common for many organisations and typically well-patched.

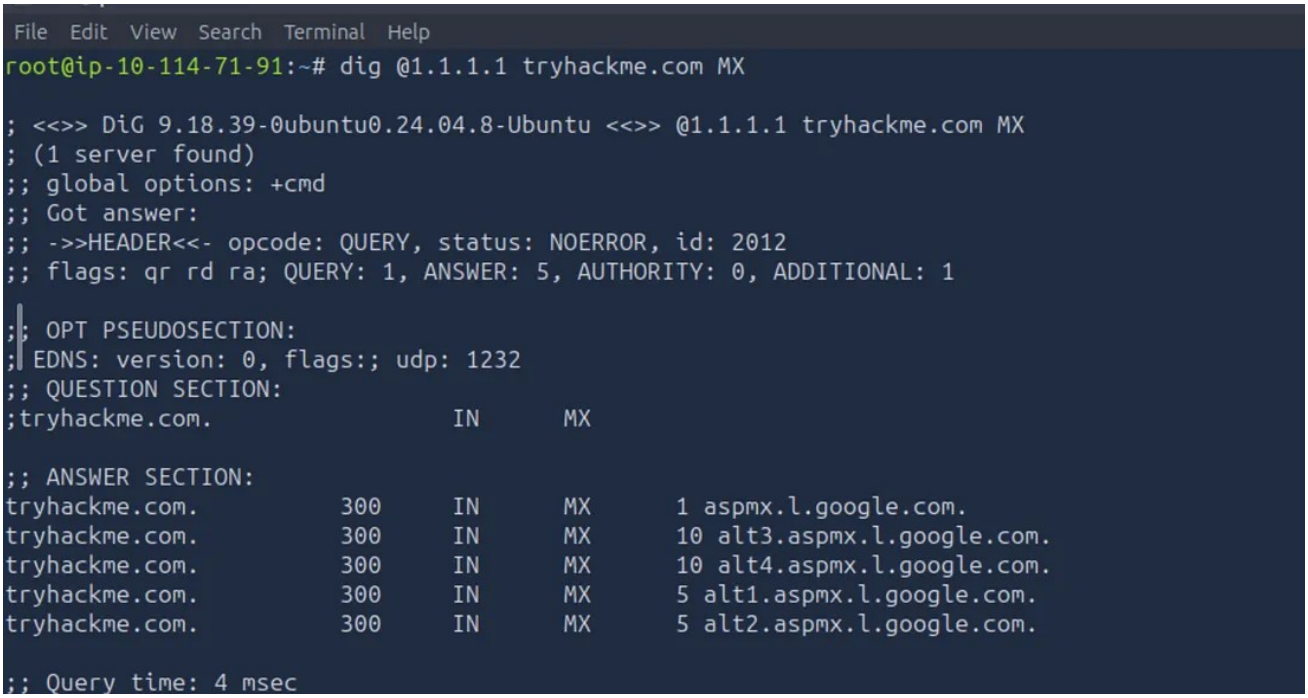
dig

`dig`

is the modern, preferred DNS query tool.

Syntax: `dig [@SERVER] DOMAIN_NAME [TYPE]`

Example (MX records via Cloudflare):



Privacy tip: Use public resolvers like `1.1.1.1`

(which supports DNS over HTTPS and DNS over TLS) to avoid your ISP logging your queries.

Defender note: Monitor for unexpected DNS changes (new MX records, rogue TXT entries). These can be signs of subdomain takeover or configuration errors.

On the AttackBox, open a terminal and use `nslookup`

or `dig` (recommended) to answer the following questions.

Q 7- Check the TXT records of thmlabs.com. What is the flag there?

Answer : THM{a5b83929888ed36acb0272971e438d78}

We can find two methods

1- nslook up

and use that command “ nslookup -type=txt thmlabs.com”

```
root@ip-10-114-71-91:~# nslookup-type=txt thmlabs.com
nslookup-type=txt: command not found
root@ip-10-114-71-91:~# nslookup -type=txt thmlabs.com
Server:         127.0.0.1
Address:        127.0.0.1#53

Non-authoritative answer:
thmlabs.com     text = "THM{a5b83929888ed36acb0272971e438d78}"

Authoritative answers can be found from:
```

2- dig method

and use that command “ dig thmlabs.com TXT “

```
File  Edit  View  Search  Terminal  Help

root@ip-10-114-71-91:~# dig thmlabs.com TXT

; <<>> DiG 9.18.39-0ubuntu0.24.04.8-Ubuntu <<>> thmlabs.com TXT
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 42626
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;thmlabs.com.                   IN      TXT

;; ANSWER SECTION:
thmlabs.com.            66      IN      TXT     "THM{a5b83929888ed36acb0272971e438d78}"

;; Query time: 0 msec
;; SERVER: 127.0.0.1#53(127.0.0.1) (UDP)
;; WHEN: Thu Oct 22 21:39:05 UTC 2026
;; MSG SIZE  rcvd: 90

root@ip-10-114-71-91:~#
```

Task 5- DNSDumpster

Standard DNS lookups (`dig`

/ `nslookup`) only resolve names you already know. They will not reveal unadvertised subdomains like `blog.tryhackme.com` , `app.tryhackme.com` , or `dev.internal.company.com` .

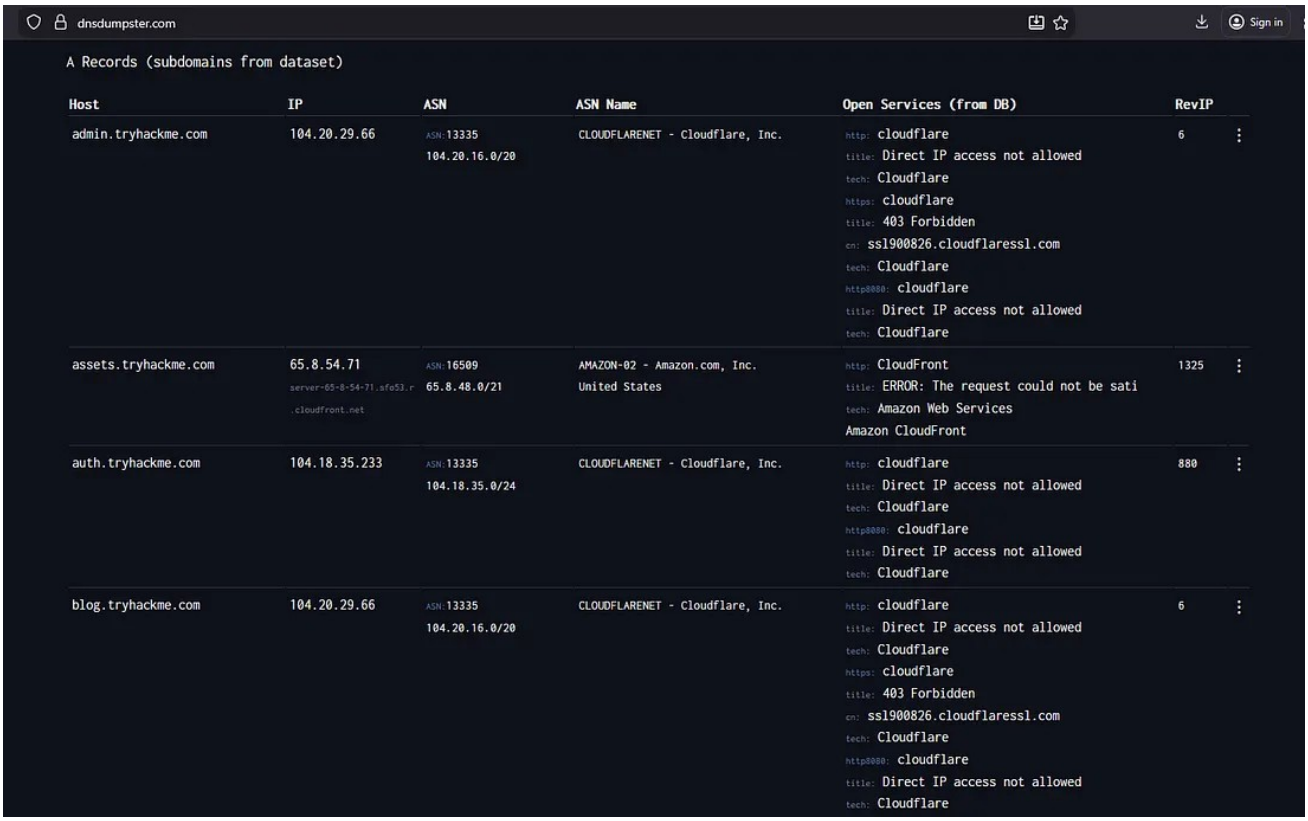
Subdomains matter because they often expose forgotten or vulnerable services (outdated CMS installations, development panels), shadow IT or misconfigured applications, and additional attack surface such as exposed APIs or admin portals.

In passive recon, these subdomains are discovered using public OSINT sources with no queries sent to the target.

One well-known free tool is **DNSDumpster**. It aggregates public DNS data from sources such as search engine caches, zone transfer databases, and certificate records. It does not perform brute-force enumeration, which means it remains fully passive. The results include subdomains and hosts, resolved IPs with geolocation, MX, TXT, and CNAME records, and visual maps showing the relationships between these.

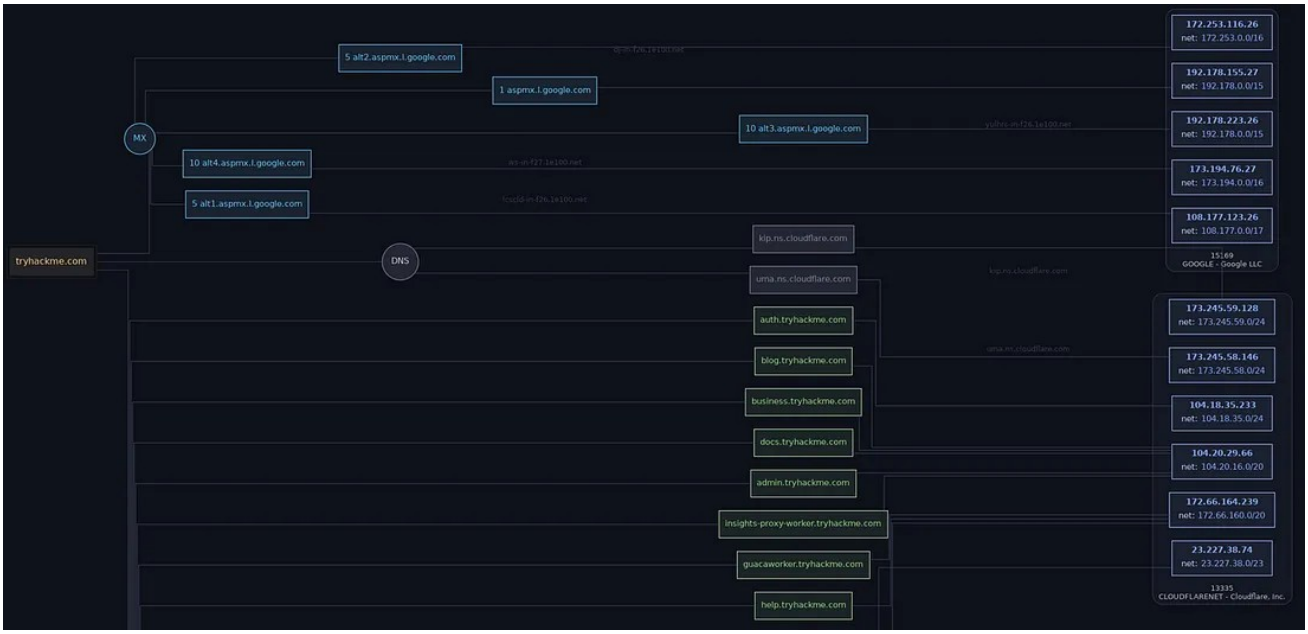
Search for `tryhackme.com`

on DNSDumpster and you will see entries like `blog.tryhackme.com` that basic DNS lookups miss.



DNSDumpster also graphs the data, showing how subdomains, IPs, and mail

servers relate to each other:



Certificate Transparency (CT) Logs

The most effective passive subdomain discovery method today is **Certificate Transparency logs**, accessible through **crt.sh**.

Certificate Transparency is a public logging framework (mandatory since approximately 2015) that records every SSL/TLS certificate issued by participating Certificate Authorities. Each certificate contains a **Subject Alternative Name (SAN)** field listing the domains and subdomains it covers. By searching these logs, you can discover subdomains without sending any traffic to the target.

To use crt.sh, visit `https://crt.sh`

and search for `%.tryhackme.com`. The `%` wildcard matches any subdomain. The results will list every certificate issued for subdomains of `tryhackme.com`, often revealing 10 to 100 times more subdomains than DNSDumpster alone.

crt.sh is fully passive, operates in real time, and has no rate limits for basic use.

Other passive subdomain discovery options include SecurityTrails (free limited searches) and command-line tools like Subfinder, which aggregate multiple passive sources.

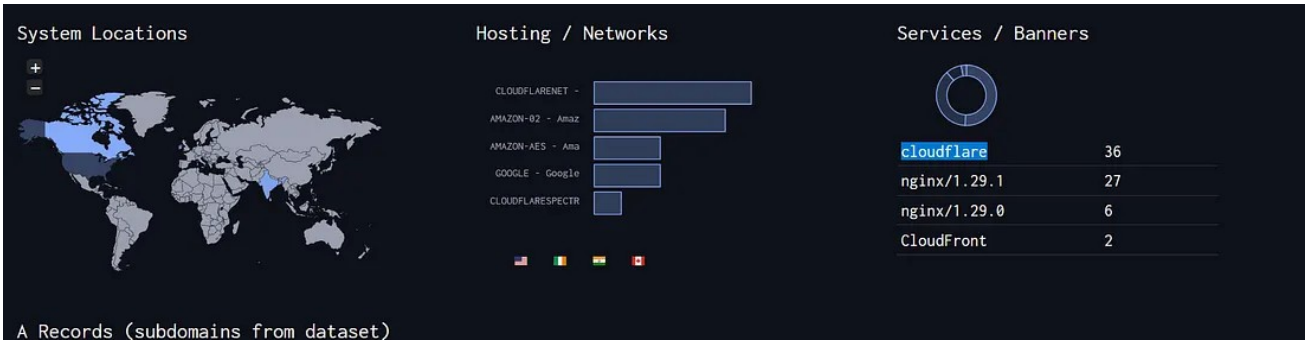
Defender perspective: Organisations monitor CT logs and subdomain lists to catch dangling DNS records (which carry subdomain takeover risk) or

unauthorised subdomains.

Use the web browser on the AttackBox, or your own system, to answer the following questions.

Q 8- Lookup tryhackme.com on DNSDumpster. Under **Services / Banners**, which one has the highest count?

Answer : cloudflare



Task 6- Shodan.io

During passive reconnaissance, tools like **Shodan.io** allow you to gather intelligence on a target’s internet-facing assets without sending any traffic to them.

Shodan is a search engine for internet-connected devices. It continuously scans the public internet, collects banners and responses from open ports and services, and indexes them for search. Unlike Google, which indexes web pages, Shodan focuses on devices: servers, IoT equipment, cameras, routers, industrial control systems, and more.

Defensive value: Organisations monitor Shodan (via alerts or manual checks) to identify unintended exposures such as rogue servers, forgotten test machines, or vulnerable services.

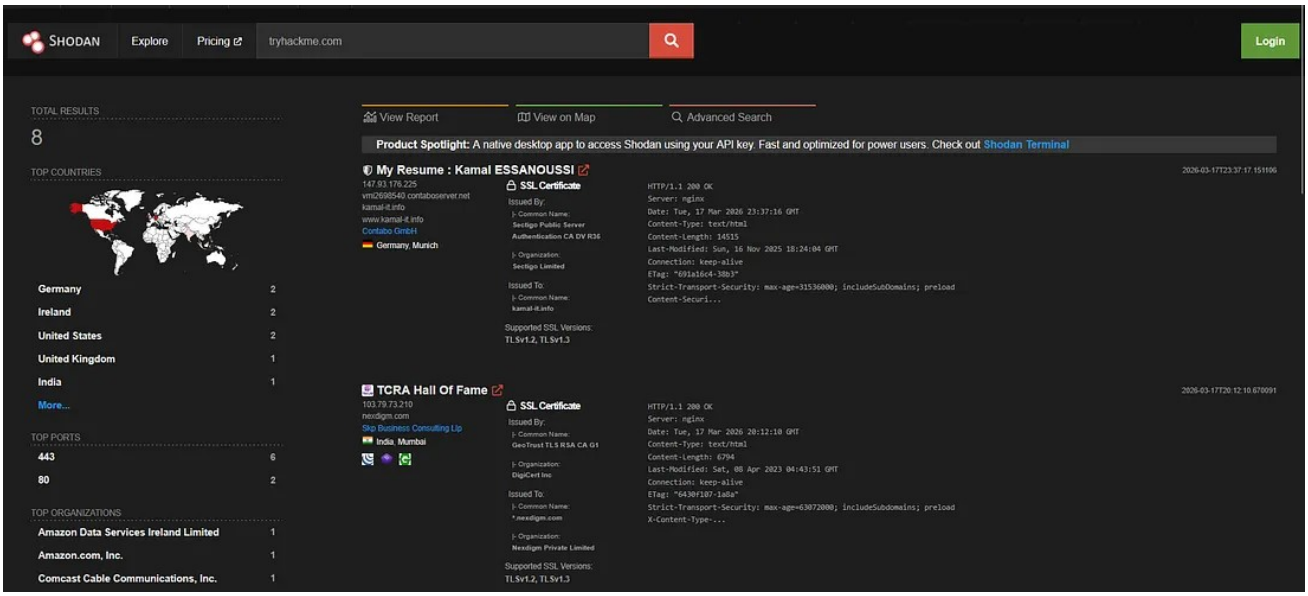
Navigating the Shodan Interface

To begin, navigate to `https://www.shodan.io`

. No account is required for basic searches. Enter a domain name (e.g., `tryhackme.com`) or an IP address from your earlier DNS lookups (e.g., `104.26.10.229`) into the search bar.

The results page displays a list of matching hosts. Selecting a host opens a detailed view containing the following information:

- **IP address** and **ASN** (Autonomous System Number): identifies the network block.
- **Hosting provider/organisation** (e.g., Cloudflare, AWS): reveals the infrastructure behind the domain.
- **Geographic location** (country, city): approximate physical location of the server.
- **Open ports and services**: with version strings and banners (e.g., HTTP server type and version).
- **Tags**: such as `cdn` or `vuln` if a known vulnerability matches the detected service version.



Search Tips

Shodan supports a range of search filters for narrowing results:

- `hostname:tryhackme.com` matches a specific hostname.

- `org:"TryHackMe"` filters by organisation name.
- `port:443 country:US` filters by port and country.
- `http.component:"wordpress"` identifies technology stack (if exposed).

For the full reference, see: https://help.shodan.io/the-basics/search-query-fundamentals

For further exploration, **Censys.io** (free basic searches) provides similar host and certificate data. It can serve as a useful complement when cross-referencing results.

Exercise

1. Go to `https://www.shodan.io` (no account needed for basic searches).
2. Search one of `tryhackme.com`'s IPs (from Task 4, e.g., `104.26.10.229`) or use `hostname:tryhackme.com`.
3. Explore the results: note the provider (Cloudflare), location (US), open ports (443/HTTPS is common), and banners.

Use Shodan to answer the questions below. All answers are visible without a premium account.

Q 9- According to Shodan.io, what is the first country in the world in terms of the number of publicly accessible Apache servers?

Answer : United States

Q 10- Based on Shodan.io, what is the 3rd most common port used for Apache?

Answer : 8080

Q11- Based on Shodan.io, what is the most common port used for nginx?

Answer : 80

Task 7- Summary

This room covered gathering intelligence without direct interaction with the target: the stealthiest phase of reconnaissance.

Key tools and techniques:

- **WHOIS:** Domain registration details including registrar, dates, and name servers. Most personal details are now redacted for privacy.
- **DNS lookups:** A/AAAA (IP addresses), MX (mail servers), TXT (SPF/DMARC/ verification), and other record types, queried via public resolvers like `1.1.1.1`.
- **Subdomain enumeration:** DNSDumpster for DNS aggregation and graphing, and crt.sh for Certificate Transparency log searches, which is the most effective passive method for discovering subdomains via public SSL/TLS certificates.
- **Exposed services:** Shodan.io for device banners, ports, and hosting information.

The practical value of these methods is that they are fully passive. They trigger no alerts, carry minimal legal risk (when used ethically and within scope), yet they often uncover forgotten subdomains, outdated services, or misconfigurations.

Command quick-reference:

Purpose	Command-line Example
Lookup WHOIS record	`whois tryhackme.com`
Lookup DNS A records (legacy)	`nslookup -type=A tryhackme.com`
Lookup DNS MX records at specific server (legacy)	`nslookup -type=MX tryhackme.com 1.1.1.1`
Lookup DNS TXT records (legacy)	`nslookup -type=TXT tryhackme.com`
Lookup DNS A records (recommended)	`dig tryhackme.com A`
Lookup DNS MX records at specific server (recommended)	`dig @1.1.1.1 tryhackme.com MX`
Lookup DNS TXT records (recommended)	`dig tryhackme.com TXT`
Passive subdomain discovery (browser-based)	Visit https://crt.sh and search `%.tryhackme.com`



Tips:

- Use DoH/DoT resolvers (e.g., `1.1.1.1`) to keep your own queries private.
- As a defender, monitor your footprint: set Shodan/Censys alerts, watch CT logs for new certificates, and track DNS changes for takeover risks.
- Even though passive recon does not touch the target directly, always ensure your overall engagement is authorised and within scope.
- Results change over time. IPs rotate (Cloudflare anycast), subdomains appear and disappear, and privacy redactions increase.

Next steps:

- Dive deeper into DNS: DNS in Detail
- Explore Shodan further: Shodan.io room
- Broaden OSINT: TryHackMe’s Search Skills and OSINT rooms, or external resources like the OSINT Framework.
- Happy hacking

Nuh hozar - Medium

Read writing from Nuh hozar on Medium. Whatever is in the name of goodness and beauty, those who know us know, those...

nuhhozar.medium.com

nuh hozar block sayfası

https://nuhhozar.blogspot.com

nuhhozar.blogspot.com

NuhHozar - Overview

Only Curiosity for cyber world. NuhHozar has 25 repositories available. Follow their code on GitHub.

github.com

Passive Reconnaissance +



Follow

Written by Nuh hozar

5 followers · 9 following

Whatever is in the name of goodness and beauty, those who know us know, those who don't know know as well as themselves.‼